

2024 Aug 30

# Design and Analysis of a Secured Token Bound Account

Cryptology and  
Information Security  
Conference 2024

Sham Chun Ning Adrian  
Hung Ka Fai Felix  
Liao Shih-Wei

# Token Bound Account

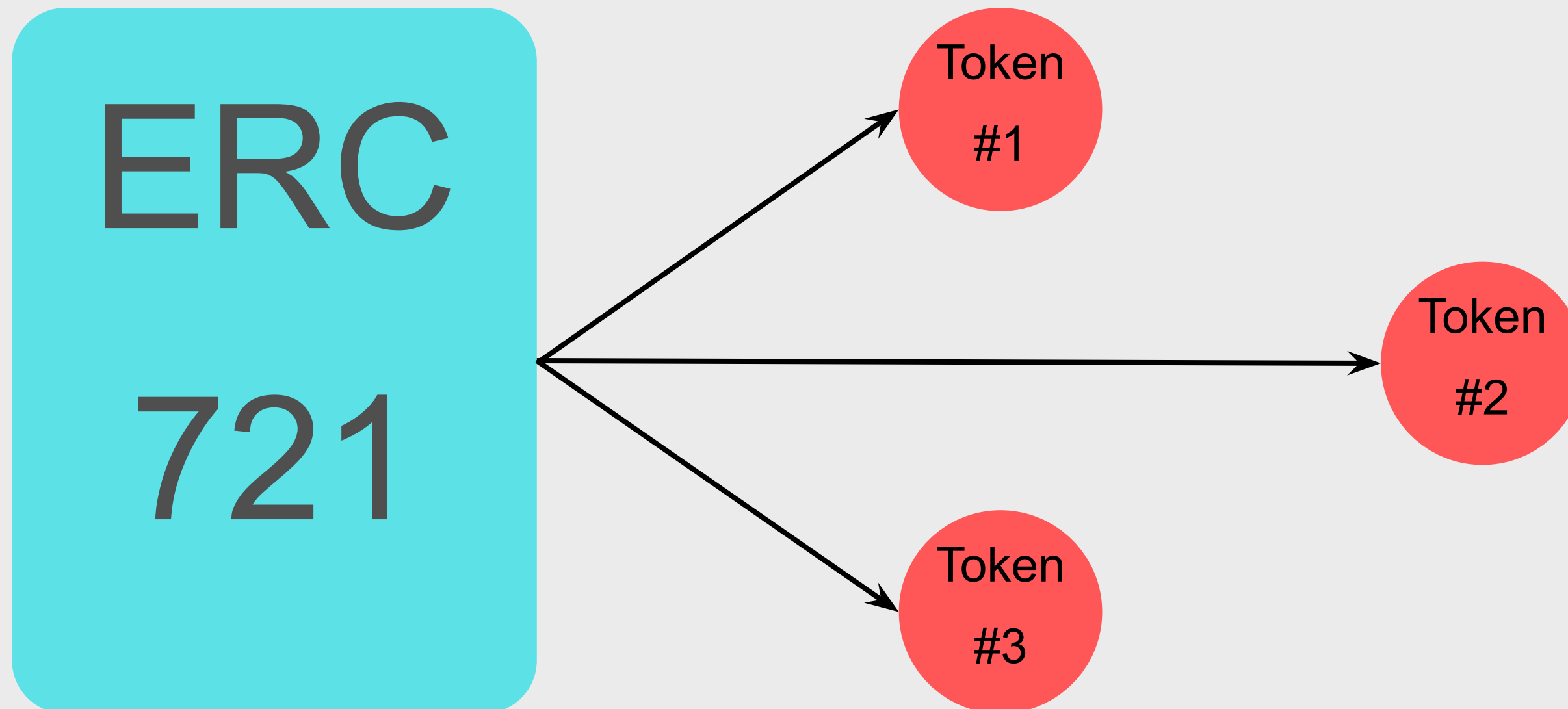
A standard that can turn any NFTs into a smart wallet on demand

Useful scenarios:

- Transfer ownership of wallet
- True representation of ownership (for example, character owns weapons)
- On-chain Identities (Avatar owns achievements, etc.)

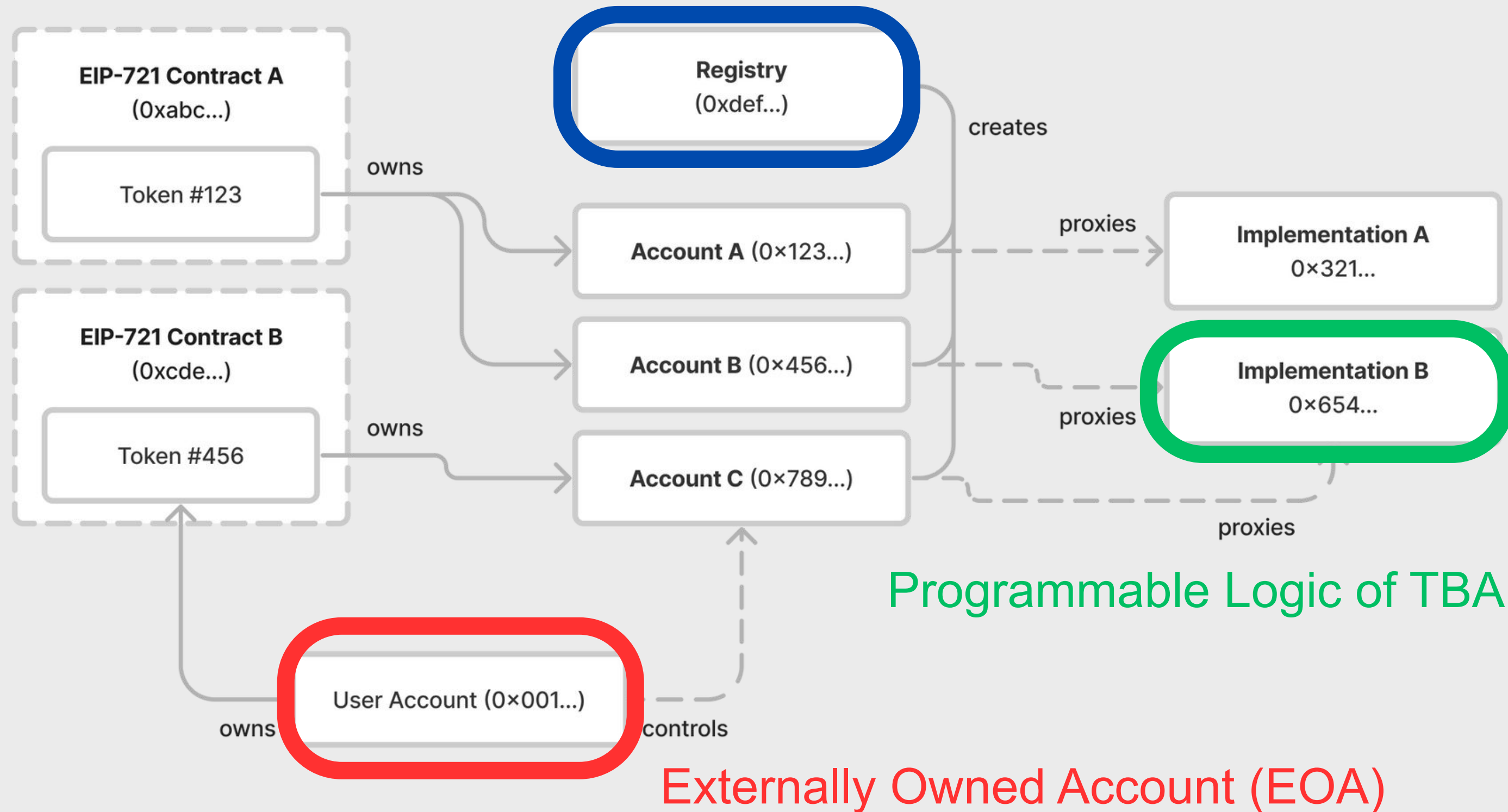
# ERC721 (Non-Fungible Token)

Standard for NFT smart contracts



# ERC6551 - Token Bound Account

ERC6551 Pre-deployed smart contract



# ERC6551 - Token Bound Account

```
function owner() public view virtual returns (address) {  
    (uint256 chainId, address tokenContract, uint256 tokenId) = token();  
    if (chainId != block.chainid) return address(0);  
  
    return IERC721(tokenContract).ownerOf(tokenId);  
}
```

```
function execute(address to, uint256 value, bytes calldata data, uint8 operation)  
external payable virtual isLocked() returns (bytes memory result)  
{  
    checkCallerIsOwner();  
    _call(to, value, data);  
}
```

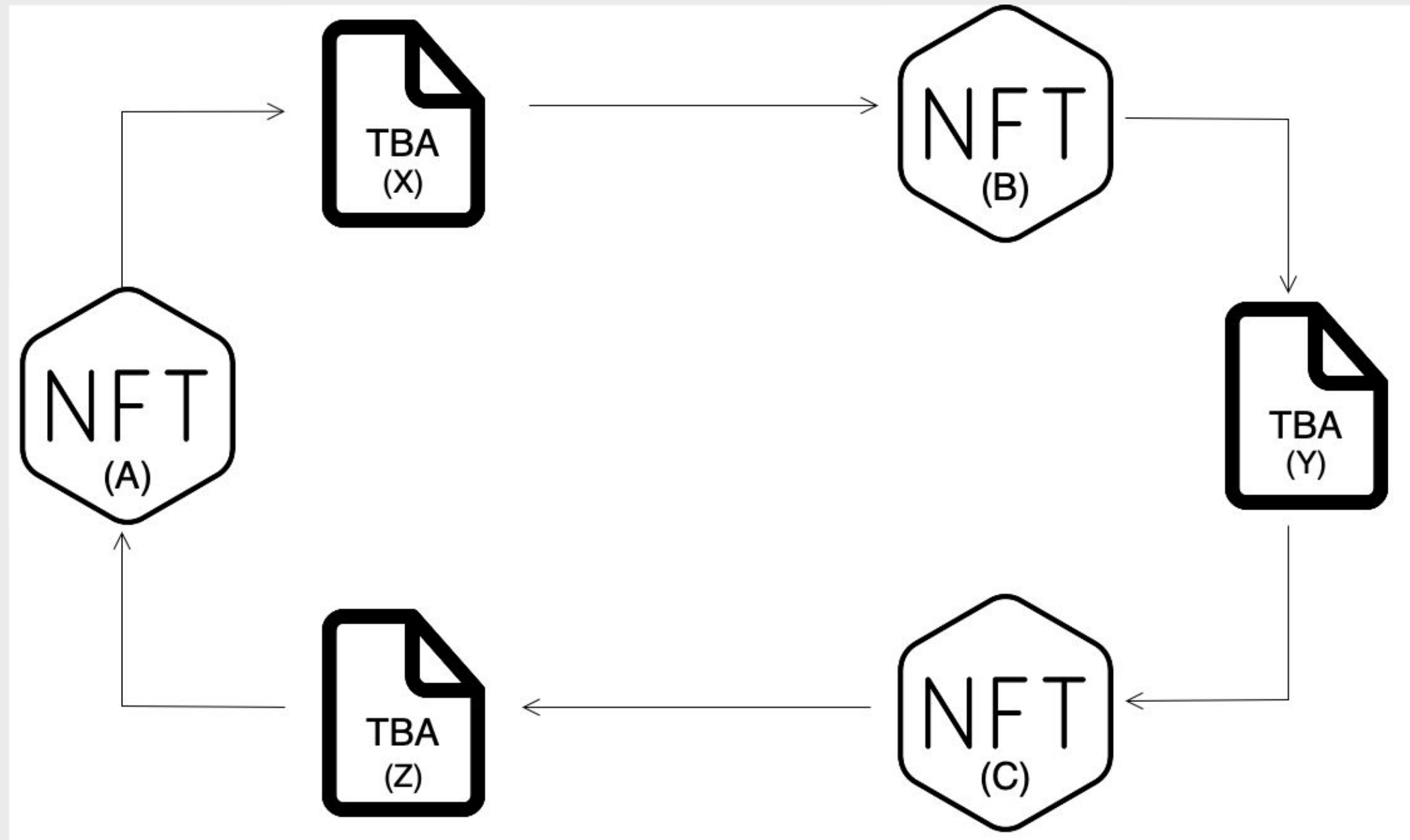


# Security Concerns

1. Ownership Cycles
2. Malicious Transfer

Both security concern is derived from the transferability of the TBA

# Ownership Cycles



# Malicious Transfer

## Front-run

1. Alice owns NFT X with TBA Y
2. Alice deposits 10ETH into Y
3. Bob sees X and offers 11 ETH to buy
4. Alice withdraws all ETH and accepts Bob's offer
5. Bob has used 11 ETH to buy X with an empty Y

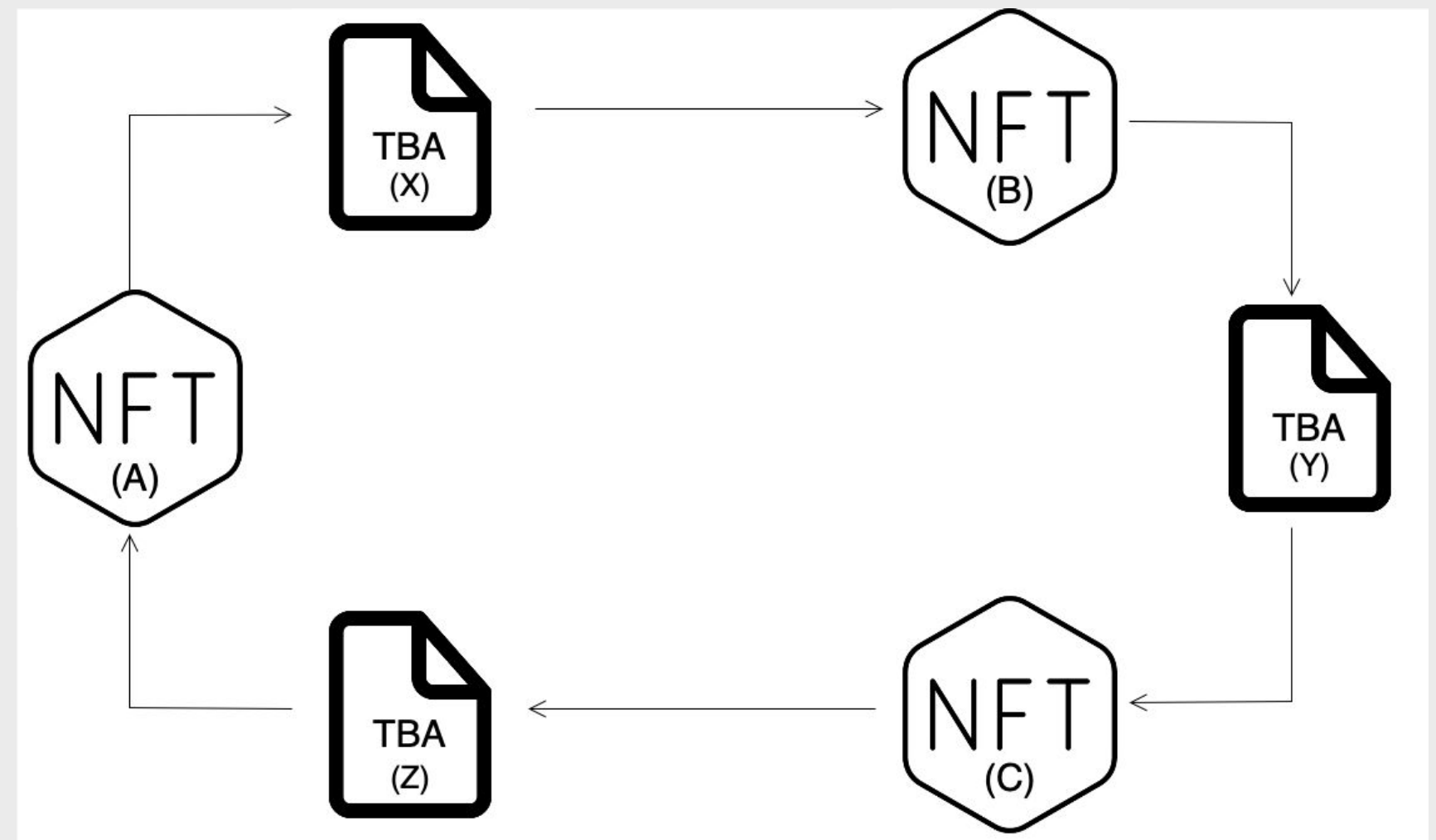
## Back-run

1. Alice owns NFT X with TBA Y
2. Alice deposits 100USDC into Y
3. Bob sees X and offers 110 USDC to buy
4. Alice pre-approves all USDC in Y for herself and accepts Bob's offer
5. After X is successfully transferred to Bob, Alice calls `transferFrom()` to withdraw all USDC from Y



# Ownership Cycles Solution

- Setup guardian accounts
  - Allow guardian accounts to ONLY transfer an NFT to a target address through a voting mechanism
- Once ownership cycle is found, guardian accounts can vote to break cycle
- CONCERNS: Loss of partial authority of TBA to guardian accounts



# Malicious Transfer Solution

Implement a Lock and Reset mechanism:

1. Block all forms of approval in execute() function
2. All forms of approvals must be done through a separate approve() function.
3. Use array or mappings to keep track of all approvals
4. Lock: Once lock is set, owner cannot call any functions for a set period of time
5. Reset: Reset all approved addresses to 0

Users can call view functions to check status of TBA, NFT marketplaces can also enforce selling mechanisms that incorporates the above features.

# Malicious Transfer Solution

## CONCERNS:

- Overhead or gas usage may be high when resetting approvals
  - May need to set a limit on number of approvals (May require resetting from time to time)
- Extra gas used during each approval
- Lock and Reset creates extra transactional cost during transfer

Thank You!